Introduction à la cybersécurité

Corrigé d'examen

Source : examen-2026-01-23-a.pdf · 20 questions

Le nom du fichier indique le 23 janvier 2026 ; l'en-tête affiche le 23 janvier 2025, série A. Le corrigé suit le fichier fourni.

Question 1 · A La disponibilité consiste à rendre le service ou la donnée utilisable par les personnes autorisées au moment où elles en ont besoin. Cela n'implique ni un accès sans restriction ni une disponibilité absolue.

Ch. 1, disponibilité, PDF p. 32–34

Question 2 · A, B, C, D Biométrie, mot de passe et preuve de possession d'une clé privée sont des méthodes d'authentification. Le MFA combine plusieurs catégories de facteurs. Chiffrer symétriquement, sans protocole de preuve, n'authentifie pas à lui seul.

Ch. 4, facteurs, MFA et défi signé, PDF p. 215–223

Question 3 · B, D Une empreinte comparée à une référence fiable révèle une modification. Une signature numérique valide confirme que le contenu signé n'a pas changé et lie le message à la clé du signataire.

À noter : Un attaquant qui peut remplacer à la fois le message et une empreinte non authentifiée peut contourner un simple contrôle par hachage.

Ch. 2, contrôle d'intégrité et signature, PDF p. 75–78, 94 et 146–149

Question 4 · A, D, E Le MFA réduit la dépendance à un seul secret. Le cours privilégie les mots de passe longs et déconseille leur rotation de routine. Documenter les mécanismes permet leur examen sans faire dépendre la sécurité du secret de leur conception.

À noter : E concerne la transparence sur les mécanismes, pas la publication des clés, secrets ou configurations sensibles.

Ch. 1, principes de Kerckhoffs, PDF p. 67–71 ; ch. 4, MFA et mots de passe, PDF p. 220–221 et 246

Question 5 · C L'authentification vérifie l'identité revendiquée. L'autorisation intervient ensuite pour décider ce que cette identité peut faire.

Ch. 4, authentification et contrôle d'accès, PDF p. 215–222 et 309–311

Question 6 · B, C, D, E, G Un certificat indique notamment sa période de validité, son numéro de série, son sujet, son émetteur et l'algorithme utilisé par celui-ci pour le signer. La clé privée ne figure pas dans le certificat et c'est normalement l'émetteur qui signe.

À noter : Le numéro de série est unique au sein des certificats d'un même émetteur.

Ch. 3, certificats X.509 v3, PDF p. 181, 185 et 197

Question 7 · C Une signature invalide signale que la vérification cryptographique du certificat a échoué. Un certificat falsifié est une explication probable ; un émetteur inconnu et une date expirée sont des erreurs distinctes.

Ch. 3, erreurs de certificat, PDF p. 186

Question 8 · B, C Une KDF dérive une clé symétrique d'un secret et peut produire une sortie plus longue à partir d'une clé. Une KDF de mot de passe augmente le coût d'une attaque par dictionnaire, sans rendre celle-ci impossible.

À noter : Une sortie plus longue ne crée pas d'entropie supplémentaire dans le secret initial.

Ch. 3, dérivation de clé, PDF p. 178 ; ch. 4, attaques par dictionnaire, PDF p. 244–245

Question 9 · E Merkle–Damgård part d'un IV fixé et traite des blocs de longueur constante avec une compression à sens unique. Chaque itération combine le bloc courant avec l'état issu des blocs précédents.

Ch. 2, construction de Merkle–Damgård, PDF p. 105–108

Question 10 · A, B Le transport RSA classique chiffre une clé de session symétrique avec la clé publique du destinataire. Sans authentification de cette clé publique, un intermédiaire peut la substituer. Une clé RSA persistante compromise permet de relire d'anciens échanges enregistrés.

Ch. 3, échange RSA et confidentialité persistante, PDF p. 169–174

Question 11 · A Une signature vérifiée avec une clé reçue prouve la possession de la clé privée correspondante, pas l'identité du détenteur. Un lien de confiance indépendant est nécessaire pour attribuer la clé à la bonne personne.

Ch. 3, association d'une clé publique à son détenteur, PDF p. 163–167 et 181–184

Question 12 · A, B Une carte et un badge sont des objets détenus. Le PIN et le mot de passe relèvent de la connaissance ; l'empreinte rétinienne et le visage relèvent de l'inhérence.

Ch. 4, catégories des facteurs d'authentification, PDF p. 218 et 220

Question 13 · B, C Le paquet intérieur est placé dans la charge utile du paquet extérieur. L'encapsulation ne retire pas systématiquement ses en-têtes et n'impose pas de déchiffrer d'éventuelles données déjà chiffrées. Les en-têtes ajoutés coûtent de la place.

À noter : Le libellé est au singulier, mais le symbole ♣ autorise plusieurs réponses ; B et C décrivent toutes deux incorrectement l'encapsulation.

Ch. 5, protocoles de tunnel et tunnel TLS, PDF p. 377–380

Question 14 · A, B On remonte de l'émetteur du certificat jusqu'à une racine déjà approuvée. Cela permet de vérifier des certificats d'autorités intermédiaires sans devoir les approuver toutes directement. La révocation reste un contrôle distinct.

Ch. 3, révocation, chaîne de confiance et racines, PDF p. 196 et 200–205

Question 15 · A, B, C, E Dans le scénario TLS du cours, les données sont chiffrées et protégées contre la modification, le certificat authentifie le serveur et le protocole protège contre le rejeu. L'authentification du client n'est pas automatique.

À noter : Le serveur peut demander un certificat client. Les données précoces 0-RTT ne bénéficient pas d'une protection intrinsèque contre le rejeu (RFC 8446, § 8).

Ch. 5, HTTPS et TLS 1.3, PDF p. 379–387

Question 16 · A, B DNSSEC signe les enregistrements ; une validation réussie permet de détecter les modifications et de rattacher les données à leur zone d'origine. Les réponses restent lisibles. Le cours appelle « non-répudiation » le lien avec l'origine signataire.

À noter : Le RFC 4033, § 3, formule les garanties standard comme intégrité et authentification de l'origine, sans garantie générale de non-répudiation. B est retenu selon le vocabulaire du cours.

Ch. 5, DNSSEC et remarques finales, PDF p. 488–489 et 527–528

Question 17 · A, D L'application cliente transmet le mot de passe au tunnel TLS sans le hacher ni le chiffrer séparément ; sur le réseau, le tunnel le chiffre. Le serveur calcule et conserve une empreinte adaptée aux mots de passe, pas le mot de passe en clair.

Ch. 4, transmission et stockage, PDF p. 238–245 ; ch. 5, tunnel TLS, PDF p. 380

Question 18 · A Un nonce donne une valeur fraîche à un échange. Un message capturé ne répond pas au nouveau défi, ce qui empêche de réutiliser directement une ancienne réponse.

Ch. 4, défi-réponse, PDF p. 249 ; ch. 5, nonces TLS, PDF p. 387

Question 19 · B, C Le domaine des messages de longueur arbitraire est infini, alors que les empreintes de taille fixe sont en nombre fini. Des messages distincts partagent donc une empreinte, et au moins une empreinte a une infinité de préimages.

À noter : L'infinité concerne des paires de messages en collision, pas le nombre d'empreintes possibles.

Ch. 2, collisions et principe des tiroirs, PDF p. 100

Question 20 · B Le vérificateur obtient une preuve que l'autre partie connaît le secret, sans recevoir ce secret. Le cours illustre ce but avec un défi signé par une clé privée qui reste chez son détenteur.

Ch. 4, authentification sans divulgation du secret, PDF p. 222–223